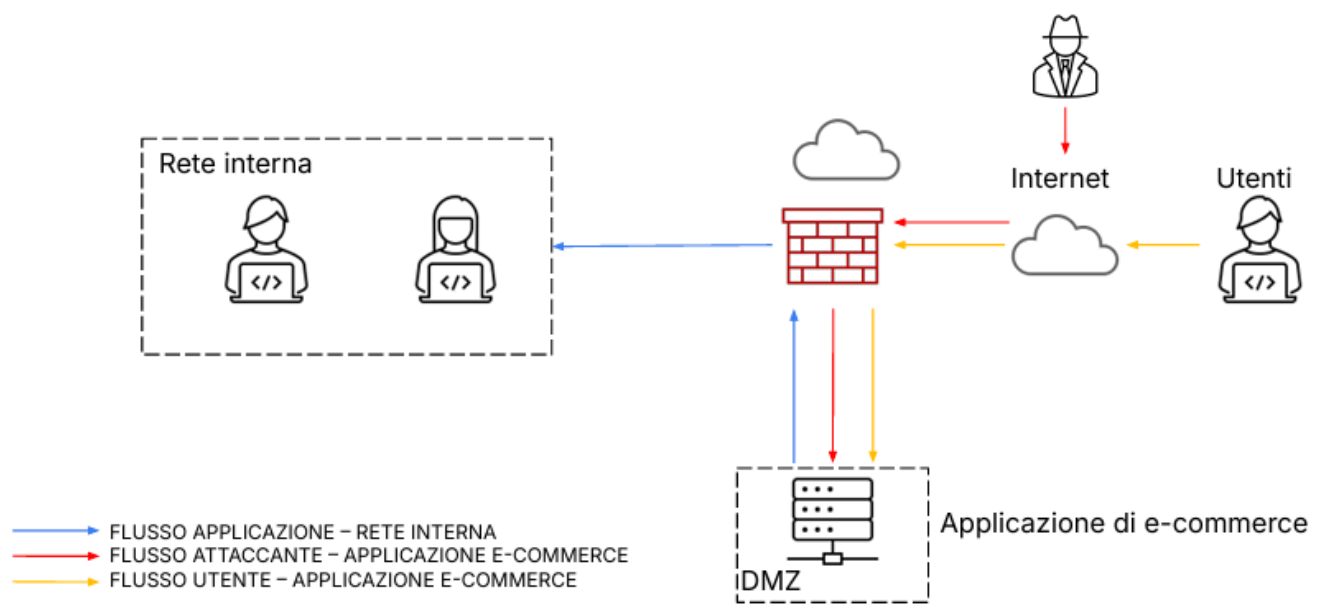


Security Operation



Situazione di partenza

1. Azioni preventive: SQLi e XSS

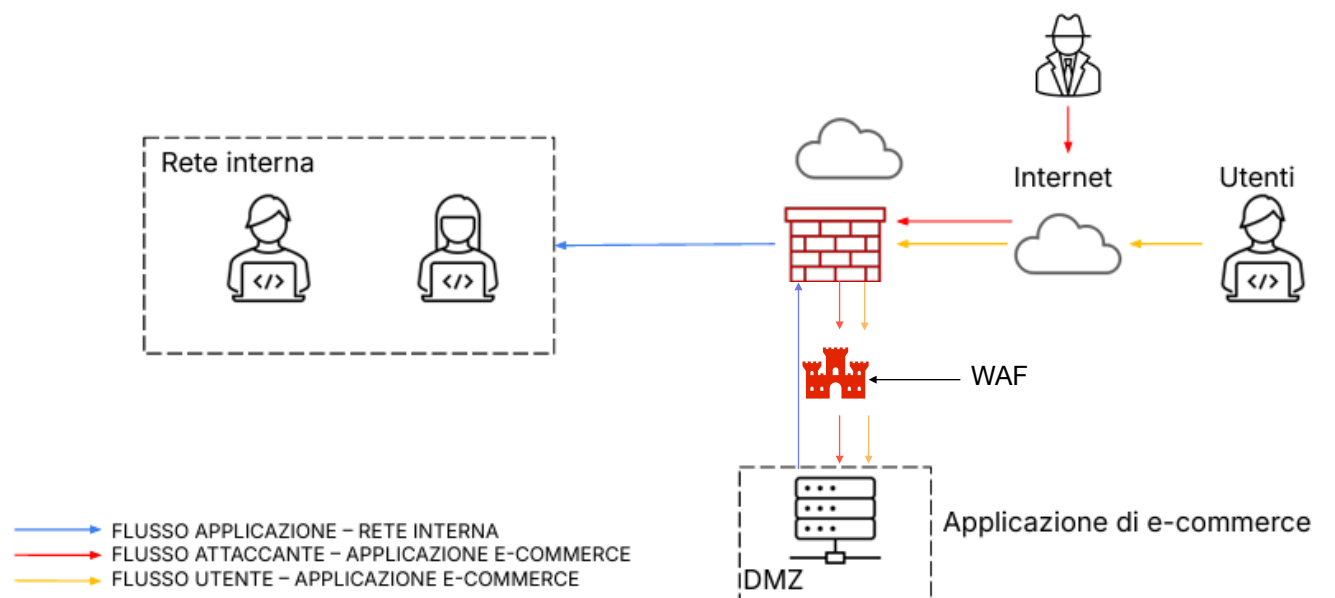
Quali azioni preventive si potrebbero implementare per difendere l'applicazione Web da attacchi di tipo SQLi oppure XSS da parte di un utente malintenzionato? Modificare la figura in modo da evidenziare le implementazioni.

Per difendere l'applicazione web da SQL Injection (SQLi) e Cross-Site Scripting (XSS), si possono implementare le seguenti azioni preventive:

- **Web Application Firewall (WAF):** È una delle difese più efficaci. Si posiziona di fronte all'applicazione e-commerce, ispezionando il traffico in entrata per identificare e bloccare attacchi noti (come SQLi e XSS) prima che raggiungano l'applicazione. Esegue validazione e sanificazione a livello di traffico.
- **Validazione e Sanificazione dell'Input:** A livello di codice dell'applicazione (all'interno dell'"Applicazione di e-commerce"), tutti gli input utente devono essere strettamente validati (controllando tipo di dato, lunghezza, formato) e sanificati (es. escaping dei caratteri speciali per SQL, encoding dell'output per XSS).
- **Prepared Statements / Query Parametrizzate:** Per SQLi, è fondamentale utilizzare query parametrizzate o prepared statements per tutte le interazioni con il database. Questo separa il codice SQL dai dati forniti dall'utente, eliminando la possibilità di iniezione di codice.
- **Content Security Policy (CSP):** Per XSS, implementare una CSP tramite header HTTP per controllare quali risorse (script, stili, immagini) possono essere caricate da una pagina web, mitigando l'impatto di eventuali script malevoli.

Modifica alla figura:

L'implementazione più visibile e importante nel diagramma è l'aggiunta di un **Web Application Firewall (WAF)**.



Azioni preventive: SQLi e XSS

2. Impatti sul business: Attacco DDoS

L'applicazione Web subisce un attacco di tipo DDoS dall'esterno che rende l'applicazione non raggiungibile per 10 minuti. Calcolare l'impatto sul business dovuto alla non raggiungibilità del servizio, considerando che in media ogni minuto gli utenti spendono 1.500 € sulla piattaforma di e-commerce. Fare eventuali valutazioni di azioni preventive che si possono applicare in questa problematica.

Calcolo dell'impatto economico:

- Durata dell'attacco: 10 minuti
- Spesa media per minuto: 1.500 €
- **Impatto economico totale:** $10 \text{ minuti} \times 1.500 \text{ €/minuto} = 15.000 \text{ €}$

Azioni preventive per attacchi DDoS:

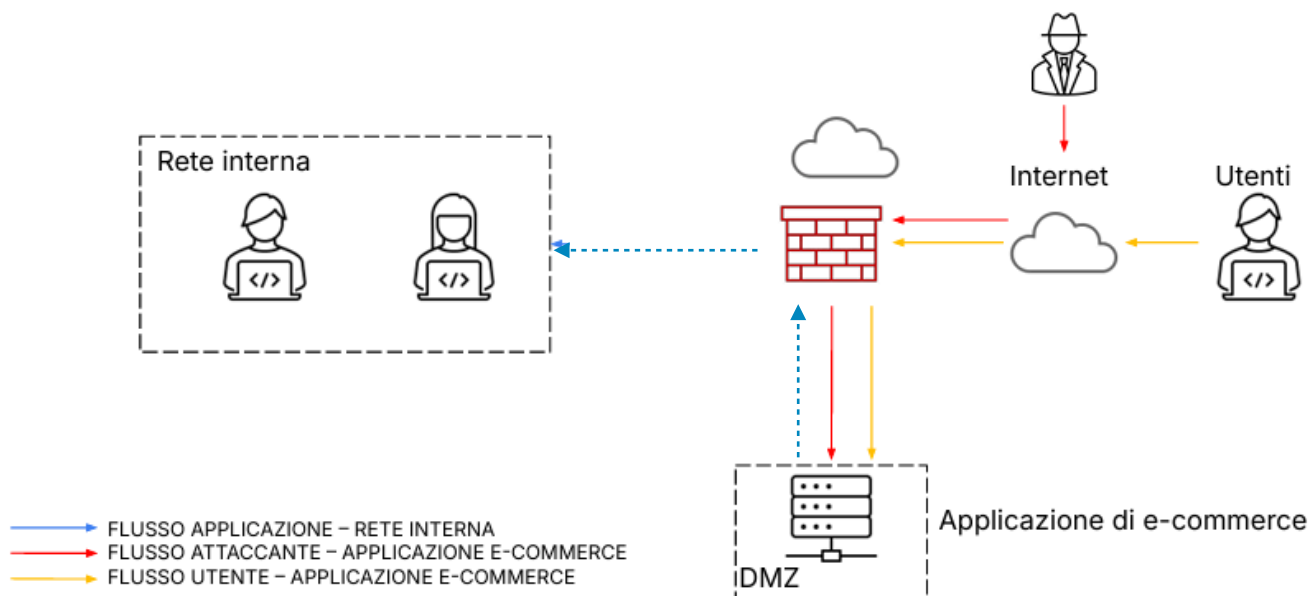
- **Servizi di Mitigazione DDoS (CDN/Protezione Cloud-based):** Questa è la prevenzione più efficace. Servizi come Cloudflare, Akamai, AWS Shield, Google Cloud Armor, ecc., sono progettati per assorbire e filtrare grandi volumi di traffico malevolo prima che raggiungano la tua infrastruttura.
 - **Nel diagramma (concettuale):** Anche se non si aggiunge una scatola all'interno della DMZ, concettualmente il traffico degli "Utenti" dovrebbe passare prima da questo servizio esterno (potresti immaginarlo come una nuvola più grande prima di Internet o tra Internet e il tuo Firewall).
- **Bilanciatori di carico (Load Balancers):** Distribuire il traffico in entrata su più istanze dell'applicazione e-commerce per evitare che un singolo server venga sovraccaricato.
- **Aumento della larghezza di banda:** Avere una larghezza di banda adeguata può aiutare a gestire picchi di traffico minori, ma non è sufficiente per attacchi DDoS su larga scala.
- **Rate Limiting:** Configurare firewall o gateway applicativi per limitare il numero di richieste da un singolo indirizzo IP in un determinato periodo.

3. Response: Malware

L'applicazione Web viene infettata da un malware. La vostra priorità è che il malware non si propaghi sulla vostra rete, mentre non siete interessati a rimuovere l'accesso dalla macchina infettata. Modificate la figura in slide 2 con la soluzione proposta.

Data la priorità di prevenire la propagazione all'interno della "Rete interna" senza necessariamente interrompere l'accesso esterno all'applicazione (che potrebbe essere utile per analisi forensi o per mantenere una parvenza di servizio, seppur compromesso), l'azione chiave è l'isolamento interno.

- **Azione:** Bloccare immediatamente tutte le connessioni in uscita dall'"Applicazione di e-commerce" verso la "Rete interna".
- **Modifica alla figura:**
 - La freccia blu "FLUSSO APPLICAZIONE - RETE INTERNA" che va dall'"Applicazione di e-commerce" verso la "Rete interna" (passando attraverso il Firewall) viene **bloccata**. La freccia con la linea tratteggiata indica che una policy del Firewall impedisce questa comunicazione.



Soluzione completa

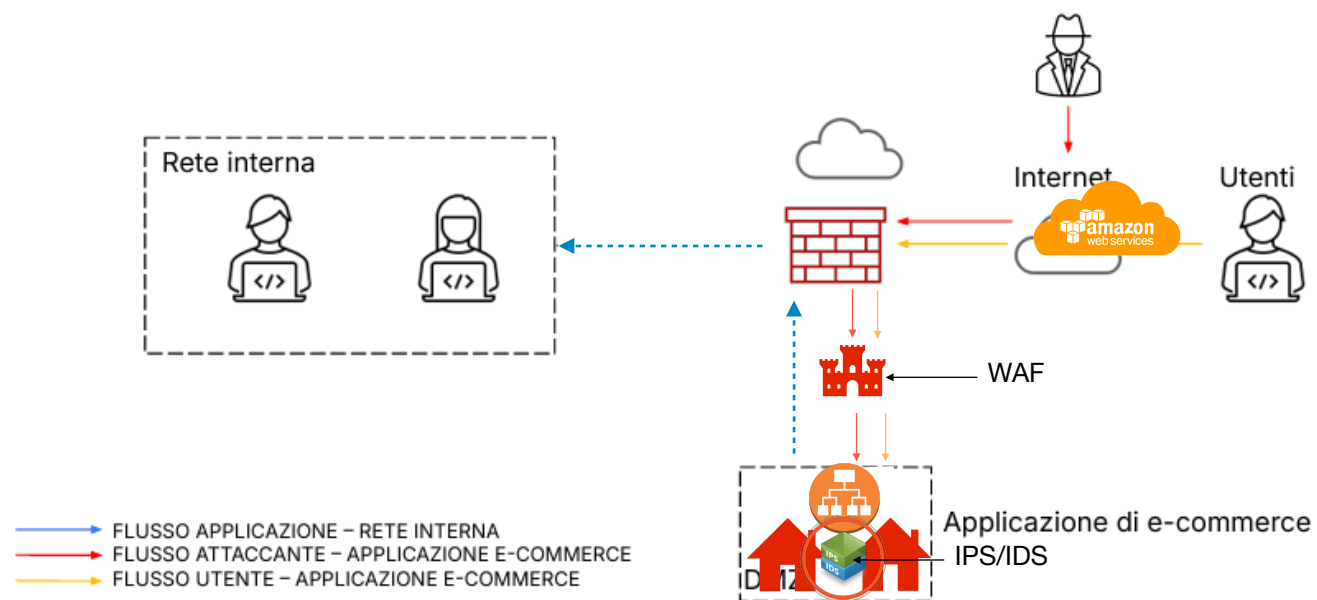
5a. Modifica "più aggressiva" dell'infrastruttura

Modifica "più aggressiva" dell'infrastruttura (se necessario/facoltativo magari integrando la soluzione al punto 2)

Una modifica "più aggressiva" implica un approccio di sicurezza più robusto e a più livelli, integrando anche le soluzioni per il DDoS.

- **Integrazione DDoS (dal punto 2):**
 - **Servizio di Mitigazione DDoS Esterno:** un'altra "nuvola" o un'icona specifica **prima** di Internet e del tuo Firewall, rappresenta un servizio di mitigazione DDoS (es. CDN con funzionalità anti-DDoS). Il traffico utente passerebbe prima da qui.
 - **Bilanciatore di Carico e Multiple Istanze App:** All'interno della DMZ, si posiziona un **Load Balancer** (bilanciatore di carico) e, invece di un singolo server per l'"Applicazione di e-commerce", si raffigurano due server identici dietro il bilanciatore. Questo migliora la disponibilità e la capacità di gestire il traffico.
- **Rafforzamento della Sicurezza nella DMZ:**
 - **IPS/IDS (Intrusion Prevention/Detection System):** Aggiungiamo un IPS/IDS nella DMZ, in linea con il traffico o in modalità di monitoraggio, per rilevare e prevenire intrusioni e attività malevole.
 - **Segmentazione della DMZ:** Se l'applicazione fosse più complessa (es. web server separato da application server), si potrebbe segmentare ulteriormente la DMZ con un firewall interno dedicato.
- **Sicurezza della Rete Interna:**
 - **Micro-segmentazione / Zero Trust:** Anche se non direttamente visibile in questo diagramma semplificato, un approccio più aggressivo includerebbe la micro-segmentazione all'interno della "Rete interna" (es. tramite VLAN, firewall interni, o soluzioni software-defined networking) per limitare la propagazione laterale in caso di compromissione. Si applicano principi di "Zero Trust", dove nessuna entità è implicitamente fidata.
- **Monitoraggio e Logging:**
 - **SIEM (Security Information and Event Management):** Si può valutare l'implementazione di un sistema SIEM che raccolga i log da tutti i componenti (firewall, WAF, server, ecc.) per una correlazione degli eventi e un rilevamento precoce delle minacce. (Non è un elemento fisico nel diagramma di rete, ma un componente critico dell'infrastruttura di sicurezza).

Questo approccio trasforma la difesa da reattiva a proattiva e multi-strato, aumentando significativamente la resilienza e la sicurezza dell'intera infrastruttura.



Modifica aggressiva

5b. Budget max 30.000€

Focalizzandosi su soluzioni che offrono un elevato ritorno sull'investimento in termini di sicurezza e resilienza, con un budget di 30.000€, è possibile implementare miglioramenti significativi, senza dover riprogettare completamente l'intera rete. L'obiettivo sarà integrare la protezione DDoS e migliorare la resilienza dell'applicazione, mantenendo la flessibilità per un'ulteriore espansione.

Ecco come si potrebbe distribuire il budget e quali soluzioni adottare:

- **Servizio di Mitigazione DDoS Esterno (Cloud-based):**
 - **Costo stimato:** 5.000€ - 15.000€ all'anno (a seconda del volume di traffico e delle funzionalità, es. Cloudflare Business/Enterprise, AWS Shield Advanced per un tier più elevato).
- **Bilanciatore di Carico (Load Balancer) e Multiple Istanze dell'Applicazione:**
 - **Costo stimato:**
 - **Soluzione hardware (es. entry-level F5, Kemp):** 8.000€ - 15.000€ per un'appliance fisica che supporta un buon throughput.
 - **Soluzione software/virtuale (es. HAProxy, Nginx Plus su VM):** 1.000€ - 5.000€ per licenze e risorse VM, più costi di configurazione.
 - **Load Balancer Cloud (es. AWS ELB, Google Cloud Load Balancing):** Costi variabili basati sull'utilizzo, potrebbero rientrare nel budget annuale.
- **Licenze IPS/IDS (Intrusion Prevention/Detection System) software o hardware entry-level:**
 - **Costo stimato:** 2.000€ - 8.000€ (per licenze software su server esistente o per un'appliance hardware entry-level).
- **Rafforzamento Generale (Configurazione/Audit):**
 - **Costo stimato:** 1.000€ - 5.000€ (per consulenza specializzata, tuning del firewall, hardening dei server, configurazione di CSP, ecc.).
 - **Motivazione:** Una parte del budget dovrebbe essere dedicata a garantire che tutte le nuove e le esistenti configurazioni siano

ottimizzate per la sicurezza. Questo include l'affinamento delle regole del firewall, l'hardening dei sistemi operativi e delle applicazioni, e l'implementazione di pratiche di sicurezza come la Content Security Policy (CSP).

Riepilogo del Budget Esempio:

- Servizio DDoS (annuale): 10.000€
- Load Balancer (hardware/virtuale): 10.000€
- Licenze/appliance IPS/IDS: 5.000€
- Configurazione/Hardening: 3.000€
- **Totale stimato:** 28.000€ (rientra nel budget di 30.000€ e lascia un piccolo margine).

Grazie per l'attenzione